MASTER TEST PLAN: AUTHENTICATION MODULE

End-to-End Test Plan for Role-Based Access Control & Staff Login

BAKER TRADER ERP — QUALITY ASSURANCE

DOC ID: TP-BTERP-LOGIN-001 | v1.0.0

APPLICATION UNDER TEST	TARGET URL & MODULE
Baker Trader ERP (B2B Perishables Distribution)	https://admin-web-production-7006.up.railway.app/login

AUTHOR / PERSONA	EXECUTION STATUS
Senior Test Engineer (15 yrs BFSI, Healthcare, ERP)	GENERATED & PLANNED — EXECUTION NOT RUN

1. TEST PLAN ID AND TITLE

Identifier: `TP-BTERP-LOGIN-001`

Title: Comprehensive Test Plan for Baker Trader ERP Authentication & Authorization Module.

Scope Classification: Level 3 Enterprise Test Plan complying with IEEE 829-2008 standards.

Version	Release Date	Author / Role	Summary of Changes	Status
`1.0.0`	2026-10-15	Senior Test Engineer	Complete 12-section test plan instantiated from RICE-POT prompt parameters.	BASELINE PROPOSED

2. OBJECTIVE AND REFERENCES

2. O
O

3. IN SCOPE AND OUT OF SCOPE

3.1 In-Scope Test Items (Phase 1 Playwright TS Automation)

- **Page Load & Metadata (REQ-LOGIN-001):** HTTP 200 verification, page title assertion (`Baker Trader ERP`), favicon, and layout container loading.
- **Valid Authentication (REQ-LOGIN-002):** Successful login with valid admin credentials, receipt of JWT bearer token, and deterministic navigation to the staff dashboard (`/`).
- **Invalid Credentials Handling (REQ-LOGIN-003):** Rejection of incorrect email/password combinations with user-friendly alert message (`Email or password is incorrect.`).
- **Empty Credentials Validation (REQ-LOGIN-004):** Client-side form submission prevention when email or password is left blank.
- **Special Characters & Boundary Inputs (REQ-LOGIN-005):** Input tolerance for unicode, accents, quotes, and SQL injection syntax fragments.
- **Role-Based Access Control (REQ-LOGIN-006):** Verification of privileged access rights for admin role versus standard employee restrictions.
- **Cross-Browser Compatibility (REQ-LOGIN-007):** Headless and headed test execution across Chromium, Firefox, and WebKit desktop browser engines.

3.2 Out-of-Scope Items (Deferred to Phase 2)

- **Native Mobile Applications (REQ-LOGIN-008):** Dedicated native iOS/Android binary builds (testing restricted to responsive web app).
- **Physical Hardware Lab Matrix (REQ-LOGIN-009):** Testing on physical mobile hardware devices.
- **Non-Desktop Screen Resolutions (REQ-LOGIN-010):** Viewports below 360px and 4K ultra-wide monitors.
- **Backend Penetration Testing:** Volumetric DDoS attacks and direct database stress testing without authorization.

4. REQUIREMENTS AND PLANNED COVERAGE

Requirement ID	Requirement Description	Planned Test Scenarios	Pri	Scope	Coverage
`REQ-LOGIN-001`	Login page load, title, and URL integrity	HTTP 200, title assertion, favicon, DOM elements presence	P1	IN SCOPE	100%
`REQ-LOGIN-002`	Login with valid credentials	Valid admin authentication, JWT storage, redirect to dashboard	P1	IN SCOPE	100%
`REQ-LOGIN-003`	Login with invalid credentials	Non-existent email, wrong password, error alert display	P1	IN SCOPE	100%
`REQ-LOGIN-004`	Validation on empty credentials	Blank email/password, whitespace strings, submission blocked	P2	IN SCOPE	100%
`REQ-LOGIN-005`	Special characters in credentials	SQLi strings, script tags, quotes, extended unicode tolerance	P2	IN SCOPE	100%
`REQ-LOGIN-006`	Login with different user roles	Admin privileges vs standard operator role access boundaries	P2	IN SCOPE	100%
`REQ-LOGIN-007`	Multi-browser execution	Playwright matrix across Chromium, Firefox, and WebKit	P2	IN SCOPE	100%
`REQ-LOGIN-008`	Different operating systems	Cross-OS testing (Windows/Linux/macOS)	P3	PHASE 2	Deferred
`REQ-LOGIN-009`	Different physical devices	Physical smartphone and tablet lab testing	P3	PHASE 2	Deferred
`REQ-LOGIN-010`	Different screen resolutions	Viewport testing below 360px and multi-monitor setups	P3	PHASE 2	Deferred

5. TEST APPROACH, LEVELS, AND TYPES

5.1 Multi-Tier Test Architecture

Testing follows a risk-based pyramid utilizing Playwright with TypeScript to provide deterministic E2E assertions.

- **Component & Contract Level:** Validate `react-hook-form` schema triggers on blur, and verify API responses from `/api/auth/login` (HTTP 200, 401, 403, 429).
- **End-to-End System Level:** Implement Page Object Model (POM) architecture isolating page locators and interaction flows from assertion logic.
- **Regression Level:** Maintain a fast, headless test suite executed on pull requests to prevent regressions in core authentication flows.

5.2 Test Types

- **Functional Testing:** Form submission, validation messaging, credential verification, and state navigation.
- **Security Testing:** Verify password masking, show/hide toggle behavior, and absence of credential logging in browser console/network logs.
- **Two-Factor Authentication (TOTP) Workflow:** Handle `totp_required` response payloads and transition to the 6-digit verification code input.
- **Cross-Browser Compatibility:** Parallel execution across Chromium, Firefox, and WebKit desktop browser engines.

6. ENVIRONMENT, TOOLS, ACCESS, AND TEST DATA

Category	Tool / Specification	Configuration Details
Test Environment	Railway Cloud Platform	`https://admin-web-production-7006.up.railway.app/login`
Language & Runtime	TypeScript 5.x / Node.js 20+	Strict typing enabled, modern ES syntax
Test Runner	Playwright Test	Multi-project config (Chromium, Firefox, WebKit)
Design Pattern	Page Object Model (POM)	`LoginPage.ts` encapsulating DOM selectors
Reporting	Playwright HTML Reporter	Interactive traces, screenshots on failure, video recording
CI/CD Integration	GitHub Actions Workflow	Headless parallel execution on Pull Requests

6.3 Test Data Management & Secrets Policy

Zero Hardco Creden Directiv

All credent and sec must be injected through environ variable No plair text passwo may exi code reposito

7. ENTRY AND EXIT CRITERIA

ENTRY CRITERIA (GATE IN)	EXIT CRITERIA (GATE OUT)
1. Login route returns HTTP 200. 2. Test accounts provisioned & verified. 3. Test Plan baseline approved. 4. CI runner network connectivity confirmed.	1. 100% In-Scope test cases executed. 2. ≥ 98% automated test pass rate. 3. Zero Sev 1 / Sev 2 open defects. 4. Test Execution Summary published.

8. ROLES, RESPONSIBILITIES, ESTIMATES, AND SCHEDULE

Role	Key Responsibilities	RACI Designation
Senior Test Engineer	Authored Test Plan, POM design, Playwright test scripting, defect triage	**R** (Responsible)
QA Automation Lead	Framework architecture review, CI/CD pipeline integration, sign-off	**A** (Accountable)
Fullstack Developer	Authentication API support, defect resolution, test account provisioning	**C** (Consulted)
Product Owner	Business rules sign-off, acceptance criteria sign-off, release authorization	**I** (Informed)

8.2 Effort Estimates (Total: 7 Person-Days)

- **Sprint Day 1:** Test Plan & RTM finalization, locator contract validation (1.0 Day)
- **Sprint Day 2–3:** Playwright framework setup, `LoginPage.ts` POM implementation (1.5 Days)
- **Sprint Day 4–6:** Test case automation (18 automated scenarios across REQ-001 to 007) (2.5 Days)
- **Sprint Day 7:** Cross-browser matrix execution, CI/CD pipeline integration (1.0 Day)
- **Sprint Day 8:** Defect verification, regression runs, final test report compilation (1.0 Day)

9. DEFECT MANAGEMENT AND REPORTING

Severity Level	Definition
SEV 1 - CRITICAL	Complete authentica outage; security breach; pla text creden leak.
SEV 2 - MAJOR	Core login feature broken; no viable workaroun available.
SEV 3 - MODERATE	Non-critica functional flaw or err handling inconsister
SEV 4 - MINOR	Cosmetic styling def or minor layout misalignme

10. RISKS, DEPENDENCIES, ASSUMPTIONS, AND OPEN QUESTIONS

Risk ID	Risk Description	Impact	Mitigation Strategy
RSK-01	**Rate Limiting (HTTP 429):** Automated rapid attempts trigger rate limiting.	High	Throttle Playwright parallel workers; add test runner IP to bypass list.
RSK-02	**TOTP 2FA Challenges:** Headless tests blocked if accounts enforce 2FA.	High	Provision dedicated automated test account without TOTP, or integrate dynamic OTP generator.
RSK-03	**Railway Cold Starts:** Ephemeral server spin-up causing initial test timeouts.	Medium	Implement pre-test health-check ping to wake container prior to test suite execution.

10.2 Facts vs. Assumptions vs. Open Questions

- **Confirmed Fact:** Application renders using React with client-side routing on Railway platform.
- **Proposed Assumption:** Dedicated `admin` test credentials will be provisioned by backend team.
- **Open Question:** Will secondary business personas (Driver, Warehouse Manager) authenticate through this portal or a mobile sub-client?

11. SUSPENSION AND RESUMPTION CRITERIA

Suspension: Testing will halt immediately if the target endpoint returns 502/503 errors for >10 minutes, or a Sev 1 defect completely blocks authentication. **Resumption:** Execution will resume upon hotfix deployment, environment health verification, and test account restoration.

12. TEST DELIVERABLES AND FORMAL APPROVALS

Deliverables: 1. Master Test Plan (`TP-BTERP-LOGIN-001`) • 2. Requirements Traceability Matrix (RTM) • 3. Playwright POM Test Repository • 4. Interactive Test Execution Report.

Senior Test Engineer (Autho SDET Lead)
Status: Approved & Submitted (Draft Baseline)

Signature: [Verified Digital QA Sign-Off] Date: 2026-10-15

Engineering Lead (Fullstack Auth Backend)
Status: Pending Test Account Provisioning

Signature: Date: